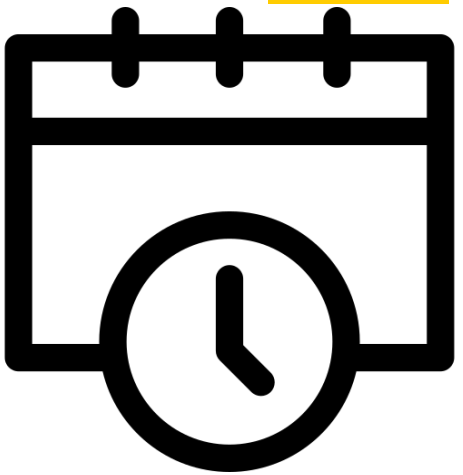
Secure Requirements Engineering



Basics, Processes and Methods

Agenda



- About Me
- terreActive / SPCS – what I do beside teaching
- Intro & Outline
- Basics Requirement Engineering / Requirements
  - Definition
  - Process & Methods
  - Techniques
- Secure Requirement

Silvan Leuenberger



silvan.leuenberger@hslu.ch

Dipl. Ing. Informatik FH, EMBA HSG

CISSP, SANS 401, IPMA Level C,
Hermes, ITIL, SAFe

Swiss Post Cybersecurity AG, Aarau

- 15+ Year's experience in IT security / consulting
- Director of Cyber defense Center, Chief Cyber Defense Officer, Swiss Post Cybersecurity AG
- Team leader
- Security Architecture of IAM Solutions
- Security Audits based on ISO 27001
- Penetration testing of webapps
- Cyber Security Assessments
- Project management
- IT Architecture & Requirement analysis

www.security.ch



www.linkedin.com/in/silvanleuenberger

Profile
About us

Swiss Post Cybersecurity AG provides security solutions to protect digital assets and data, all developed and operated in Switzerland. Headquartered in Aarau, with offices in Morges, Zurich, and Luxembourg, we enhance cyber resilience with Swiss precision and innovation. Formed in 2024 from terreActive and Hacknowledge, we are a subsidiary of Swiss Post.



Profile
About us

1996

Founding year
terreActive

2016

Founding year
Hacknowledge

2024

Swiss Post Cybersecurity AG acts completely independent of Swiss Post group's IT department and was formed in 2024 by joining the forces of two well-known market leaders: terreActive and Hacknowledge.

Organization

Joining Forces – Swiss Post Cybersecurity AG



Swiss Post acquired a majority stake in July 2023 and launched *Swiss Post Cybersecurity AG* in July 2024 by merging the companies terreActive and Hacknowledge. The merger will be completed on 1.1.2025.

Together, they can now offer companies and authorities a comprehensive range of cybersecurity solutions and thus protect digital, confidential information and data even better.



The management of terreActive AG remains active in SPCS AG. This is a change of name, the tax number remains unchanged.
No change for customers or the new total of 150 employees.



Swiss roots remain.
Head office in Aarau, branch in Morges.
Strong partnership for future growth.

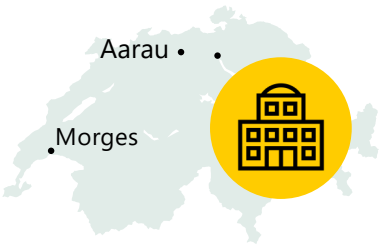
Swiss Post Cybersecurity AG

is an autonomous, market-oriented subsidiary of Swiss Post and operates completely independently of the internal IT department of the Swiss Post Group.

Profile
Our Locations



Profile
About us



Consistency

> 28 years of expertise in cybersecurity

Swiss company

swiss safety center ISO 27001 certified system

150+

Employees

105 in Aarau
43 in Morges
8 in Luxembourg

of which around 70 engineers

360° Cybersecurity

Cyber Defense Center accounts for 75 % of our business

Clients

Company sizes from SME to large enterprise

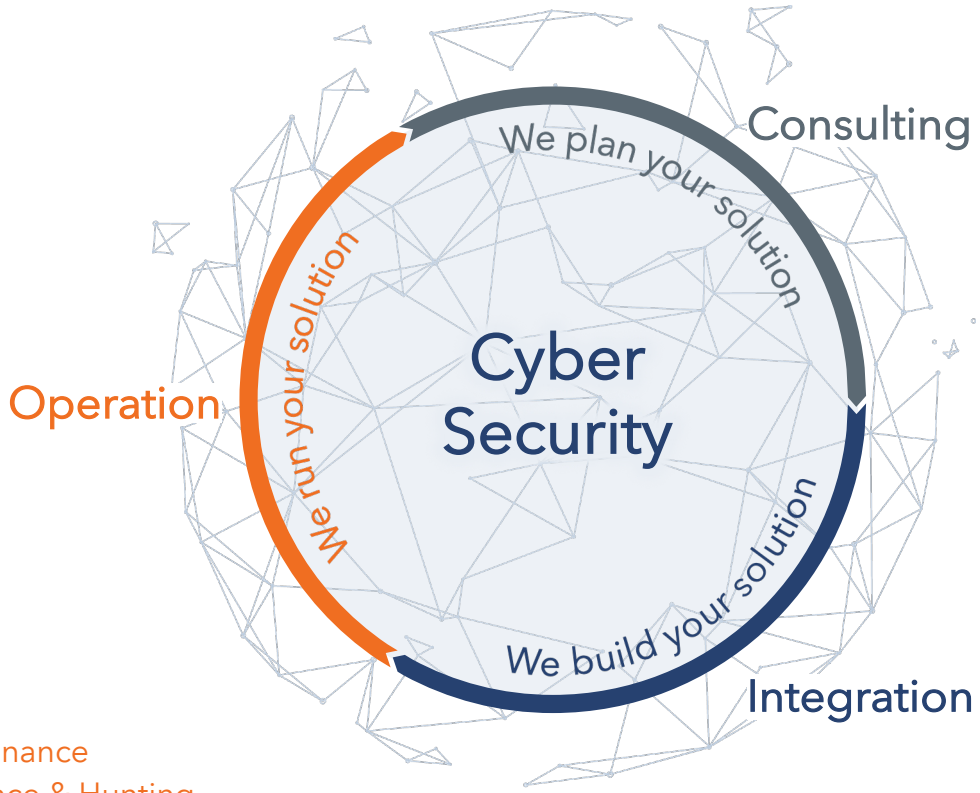
We serve all industries

Offering

Our services for your security

- Concepts
- Assessments
- Architectures
- Risk & Compliance
- CISO-as-a-Service
- Tabletop Exercise

- SOC Services
- Cyber Deception
- Forensic Analysis
- Incident Response
- SOAR-as-a-Service
- Operations Control
- Security Monitoring
- Vulnerability Management
- Managed Security Services
- Breach & Attack Simulation
- System Monitoring & Maintenance
- Threat Detection & Intelligence & Hunting



- Audits
- Penetration Tests
- Vulnerability Scan
- Red Team Service
- Social Engineering
- Phishing Simulation
- Awareness Trainings

- WAF
- SIEM
- Firewall
- Network Security
- Log Management
- Application Security
- Web & E-Mail Security
- Cyber Defense Platform
- Privileged Access Control

Offering

Consulting: We plan your solution

- Audits:
  - Penetration testing with focus on *intrusion, resilience, OWASP Top-10, Cloud, OT*
  - Social engineering campaigns incl. phishing and awareness
  - ICT minimum standard and Red Team Service

- Risk & Compliance:
  - Readiness Check
  - Security-Officer-on-Demand
  - CISO-as-a-Service
  - Tableto Exercise

- Concepts and Architecture

Your benefit

- We review your IT infrastructure → You will easily recognize points of attacks and bottlenecks.
- We recommend adjustments → You can minimize downtimes and increase your system availability.
- We have hands-on experience based on our SOC → You will receive a concept feasible and workable.

Offering

Integration: We build your solution

- Application & Network Security (FW, VPN, WAF)
- Web- & E-Mail-Security
- Privileged Access Control
- Network Detection & Response (NDR)
- Endpoint Detection & Response (EDR)
- Security Monitoring & SIEM
- Log Management & tacLOM
- Vulnerability Management
- Threat Intelligence
- SOAR
- Cyber Deception

Your benefit

- We are certified by well known supplier → This guarantees competent integration and secure solutions.
- We can just extend existing solutions or integrate complex systems → Your needs will decide.

Offering

Security Operations Center: We run your solution

Operations Control Center (OCC)

- Maintenance and Operation of IT Infrastructures, such as network, server and applications
- Maintenance and Operation of IT security components, such as firewalls, proxies, SIEM solutions
- Service costs according system or application

Incident Response Center (IRC)

- Detection of IT security incidents 24/7
- Incident respond, support
- Forensic analysis of incidents
- Tuning of Security Monitoring Solutions
- Service costs according role, effort and frequency

Your benefits

- Our experts → relieve the burden on your internal staff resources.
- Our modular system → helps you to save costs and to execute a project step by step.
- Our reports → will increase transparency.

Offering

Attack and defense under one roof



Attack

RED Team

Penetration Tester

Auditor

Password Cracker



Defense

BLUE Team

Security Analyst

Security Engineer

Threat Hunter

RED Team + BLUE Team + DEV
= more security

On the test bench
at various **capture-the-flag** events



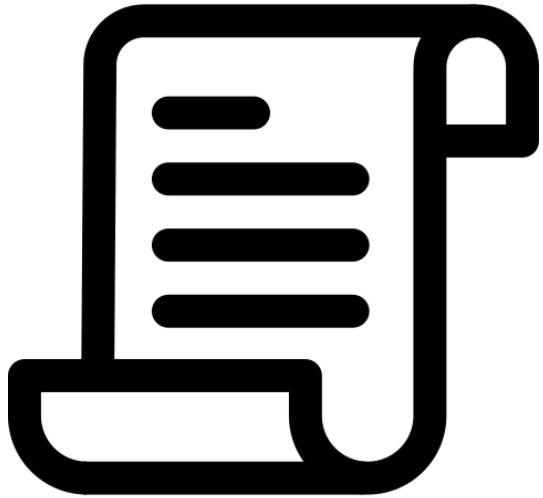
Outline

What's to be expected…



© terreActive AG

Outline



- 1 Day
  - Business Analyses & Requirements Engineering
- 2 Day
  - Security, Intrusion/Malware/Exploit, SDLC
- 3-4 Day
  - Threat Modeling, Security Design Principles and Design Patterns
- 5-6 Day
  - Case study
- 6-7 Day
  - Analysis of case study, repetition

Basics Rules

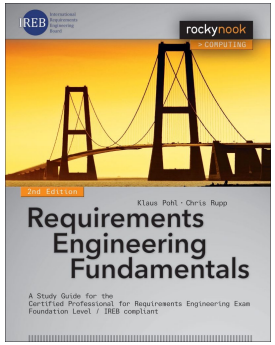
- Attention please, this may help you a lot to pass the exam
- Resist the urge to google everything right now
  - Try to reflect for yourself
- Ask questions
- We try to do some group work / interaction
  - Participate actively → Break Out Sessions
- We do flexible breaks



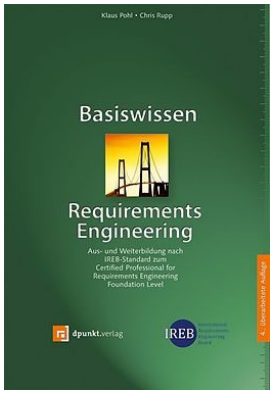
Language

- German
  - “Unterrichtssprache”
- English
  - Slides / most of the sources

Books – Requirement Engineering



- https://rockynook.com/shop/computing/requirements-engineering-fundamentals-2nd-edition/



- https://www.dpunkt.de/buecher/3986/basiswissen-requirements-engineering.html

Testat & Exam

- Repetition exercises
  - Basis for the upcoming exam
- Use-case exercise
- Final exam
  - Multiple Choice
  - Free text exercises

Testat & Exam



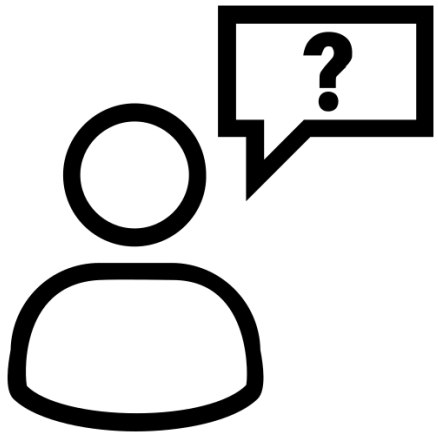
- Sec. Req. Engineering
- Presentation and exercises during lessons
- Testat exercise use-case study (Threat analysis, doc)
- Testat (hand in = done)
- **Exam = Final grade**



- Secure Coding
- Presentation and exercises during lessons
- Testat exercise covering OWASP Top 10 issues
- **Exam = Final grade**

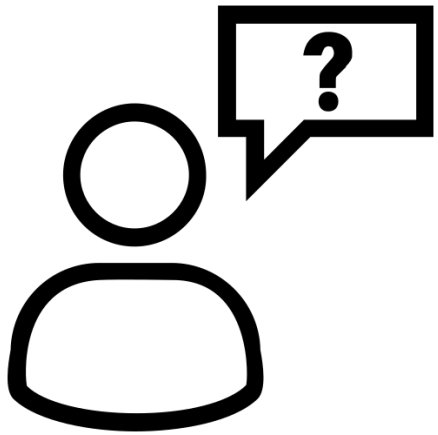
What's your Background

- Development
- Integration
- IT-Security
- Project management
- Consulting
- Non-IT



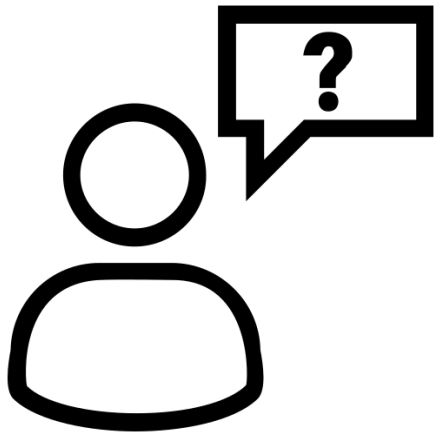
Experience

- Security
- Programming
- Networking
- Requirement engineering
- Project Management



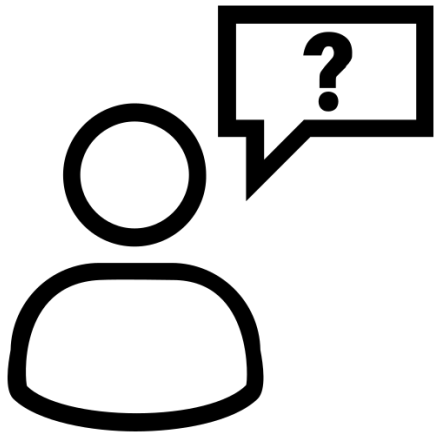
Job Situation

- Internal
- External
- Consulting



Usage of OS / HW

- Windows
- OSX
- Linux
- Something else



INTRO

Security…

<irony degree="minor">

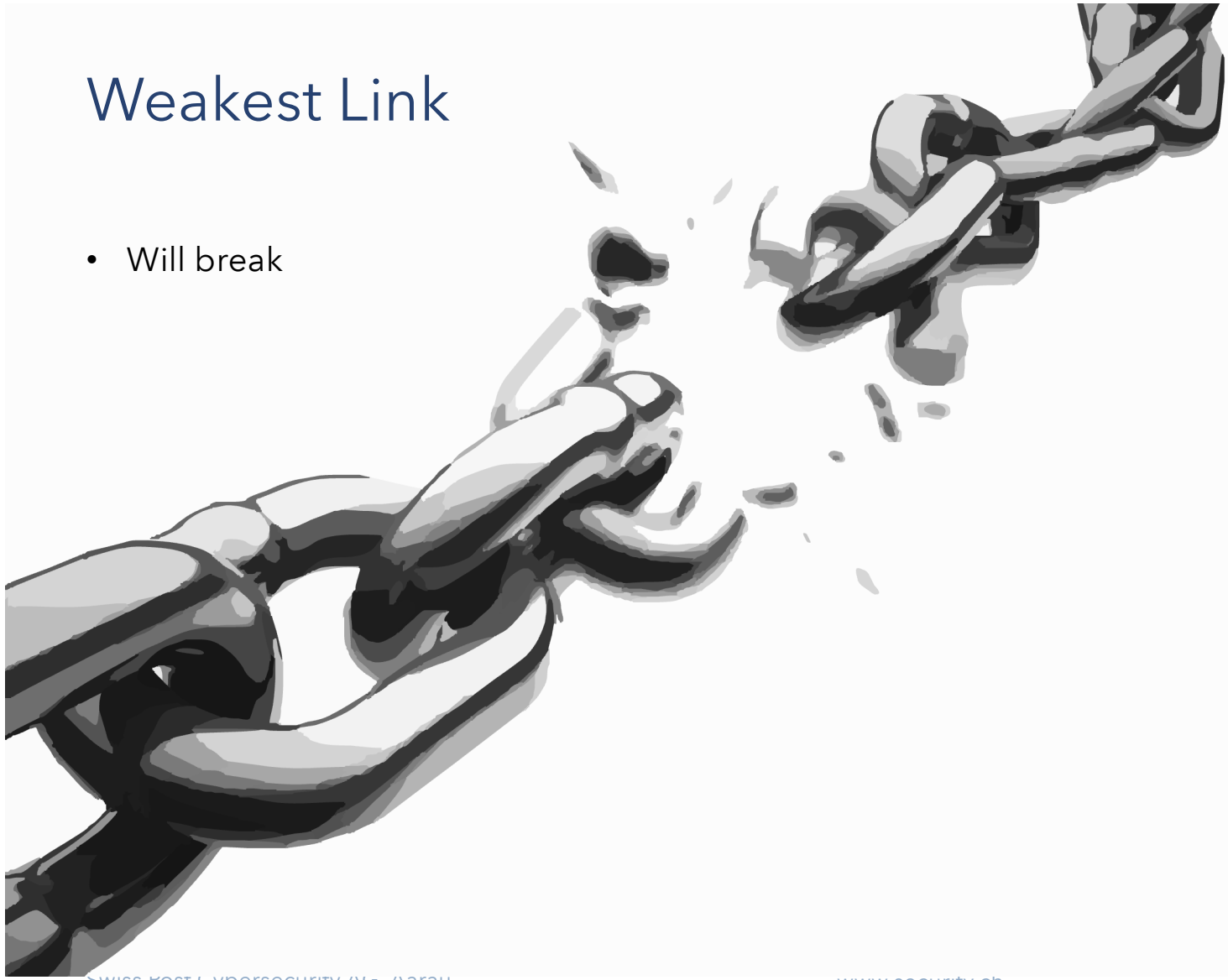


</irony>

https://www.signiant.com/wp-content/uploads/2015/02/Dilbert-on-Security.jpeg

Weakest Link

- Will break



Motivation

Nobody is 100% secure (ask the NSA)...

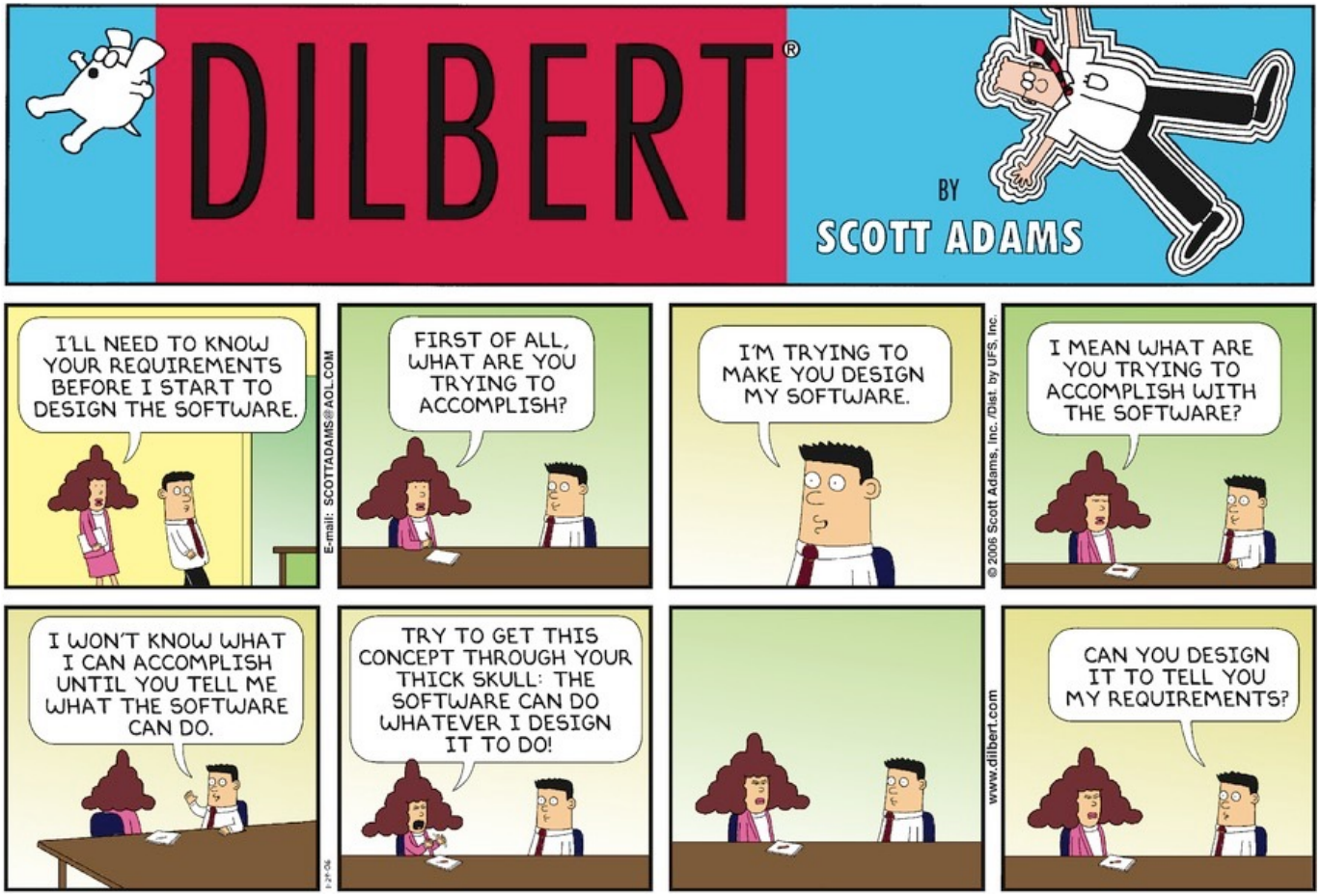
But:

- Target should be no well-known vulnerabilities in Code!
- projects → "best-of-breed secure"!
- all developers are always "security-aware"

So please:

- know the types of vulnerabilities
- avoid well-known mistakes
- use proven countermeasures / patterns (Guidelines)





https://dilbert.com/strip/2006-01-29

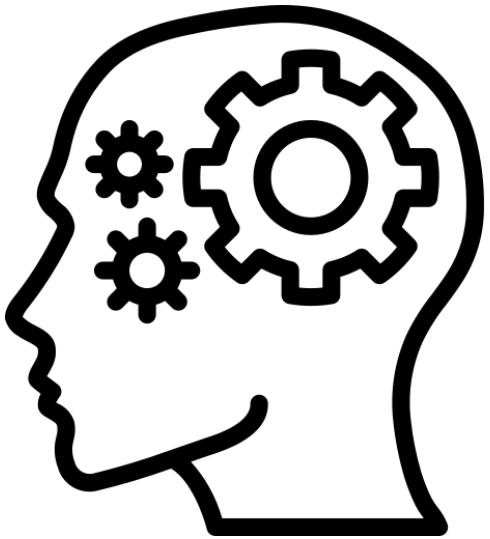
Costs of NOT doing it properly

- The earlier the better (cheaper)
- Regulations may force you to shut down
- May lose reputation which is hard tc match with $$$

Phase at which error is detected and fixed	Cost to Fix
Requirements	x1 (reference)
Design	x3 to x8
Build	x7 to x16
Test	x21 to x78
Operations	x29 to x1615, mean x250

Security is ... Know-how!

- Projects and Products
  - What have we done? How did we solve it?
- Documents
  - Consulting papers, reviews, analyses, checklists ...
- People
  - Ask! Somebody probably has done it already
- Secure Code
  - Security-aware developers!



Software Assurance (SWA)

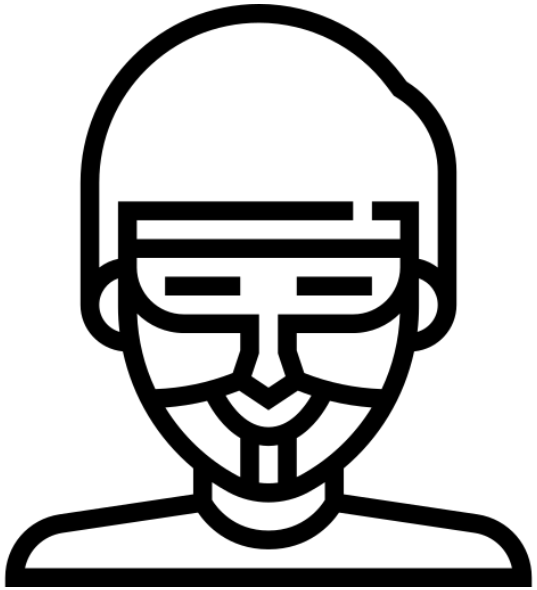
- “Software assurance (SwA) is defined as "the level of confidence that software is free from vulnerabilities, either intentionally designed into the software or accidentally inserted at any time during its lifecycle, and that the software functions in the intended manner.” ("National Information Assurance Glossary"; CNSS Instruction No. 4009)

- Key
  - Trustworthiness
    - No weaknesses that can be exploited (malicious or unintentionally)
  - Predictable Execution
    - If you execute it, its working as intended (correct function)

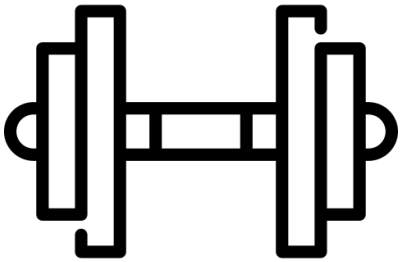
The “coder” isn’t best suited for Requirement Eng.

- Need special know-how
- Really hard for normal engineers to do
- Overcome creator blindness

- But they can be a big help
  - Know their code and how to change it
  - And the consequences of their actions



Ex: What are the most important security issues from your point of view?



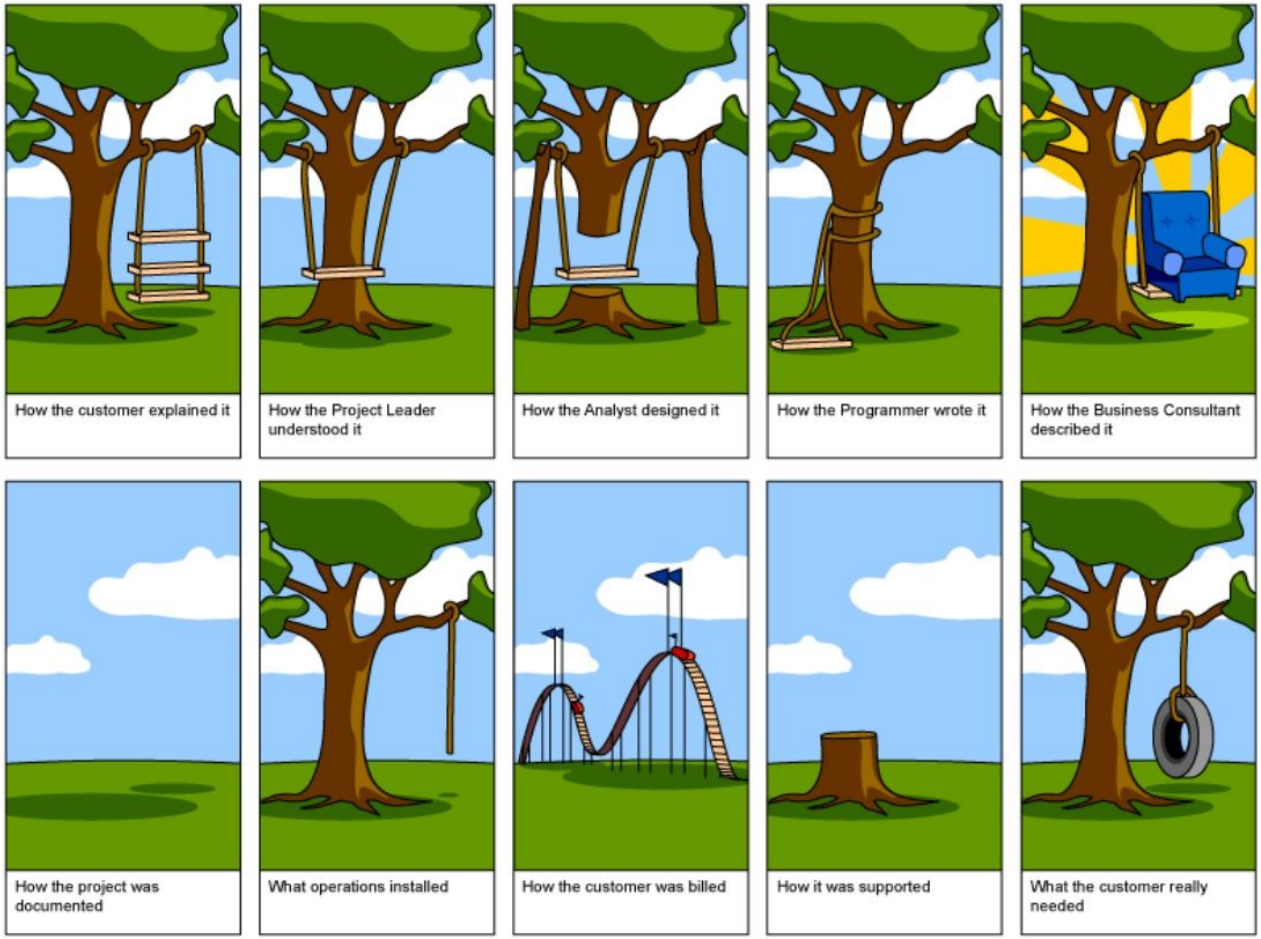
Business Analysis
"Understand the System"
That's you as a security requirement engineer!

Introduction

- What is business analysis / requirement engineering?
  - *"Business analysis is a research discipline of identifying business needs and determining solutions to business problems. Solutions often include a software-systems development component, but may also consist of process improvement, organizational change or strategic planning and policy development."*
  - *"Requirements engineering (RE) refers to the process of formulating, documenting and maintaining software requirements and to the subfield of Software Engineering concerned with this process."*

Who will collect these “Requirements”?

- The Business Analyst
- With a focus on security
- Software Engineers don’t have the main target on security



http://weblog.cemper.com/a/200309/09-typical-project-life.php

Requirement Engineer (RE) – Business Analyst (BA)

- The requirements engineer as a project role is:
  - often at the center of attention
  - direct contact with the stakeholders
  - ability and the responsibility to become as familiar as possible with the domain and to understand it as well as possible.

Why do we need to do RE by a RA

- **Clear** requirements and **complete** specification allows for:
  - accurate effort estimation
  - better planning (tasks, resources)
  - faster implementation (less dev questions, less room for assumptions)
  - better quality (less defects)
  - less CRs/rework
- Internal **knowledge of business** needs is **crucial** because:
  - Business stakeholders are not always available (e.g. to answer very specific dev questions)
  - Business stakeholders might not see the “big picture”
  - It’s good to have a “Single point of contact” both for developers and for business

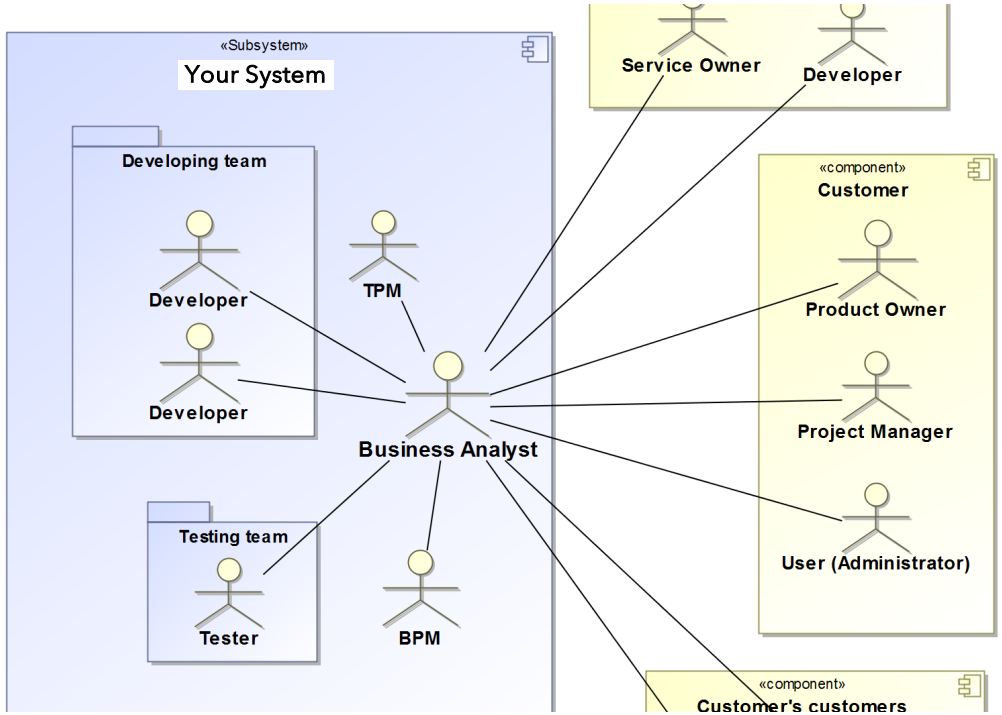
Central role of a BA/RA

Don’t mind the gap…

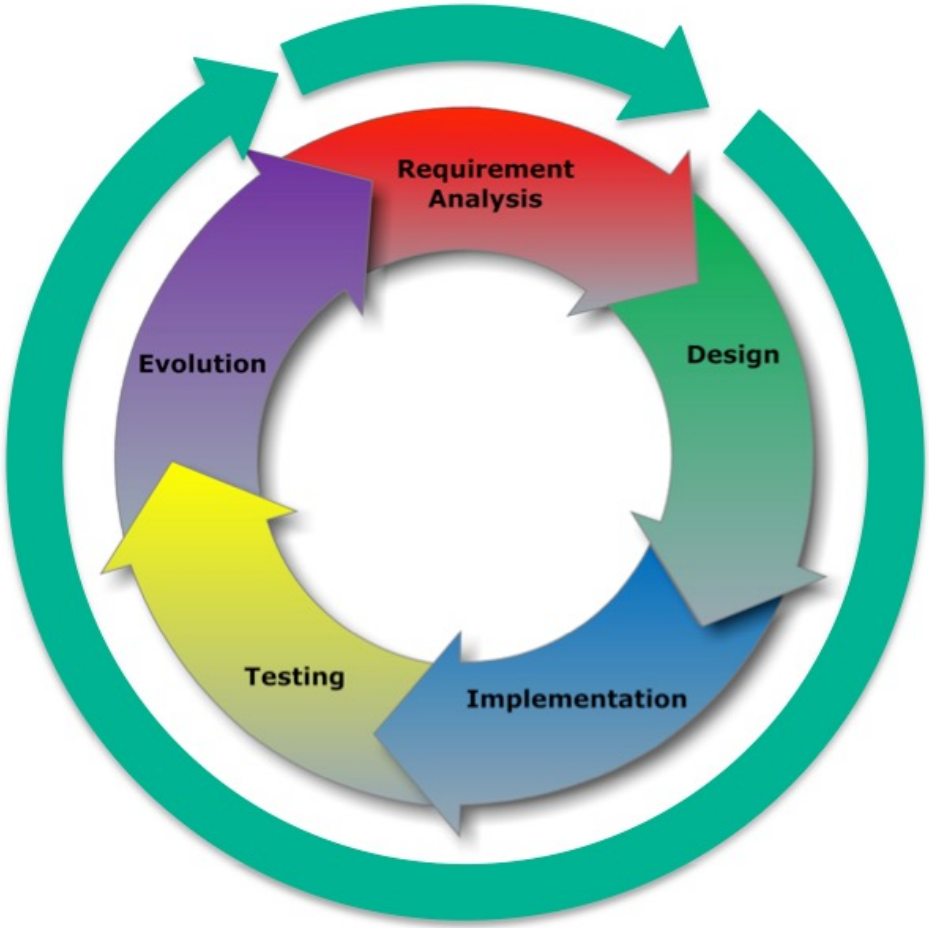


Credit: Thinkstock

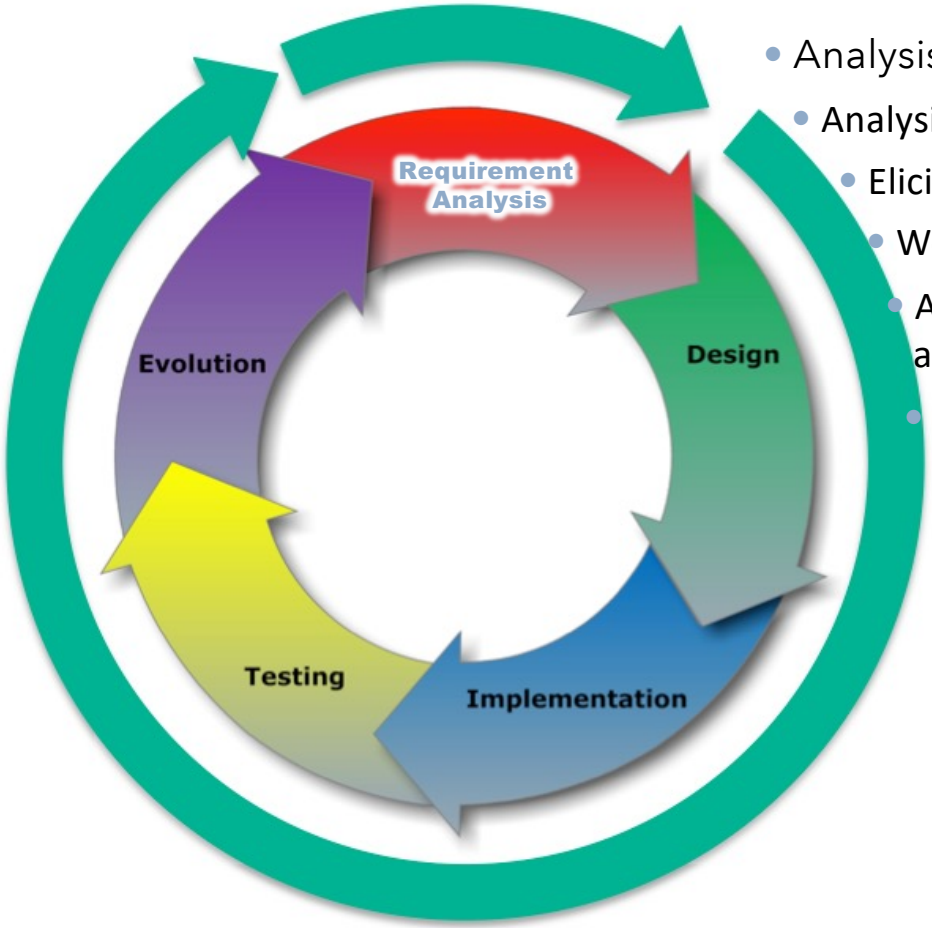
Collaborate…



Role of RA in project life-cycle

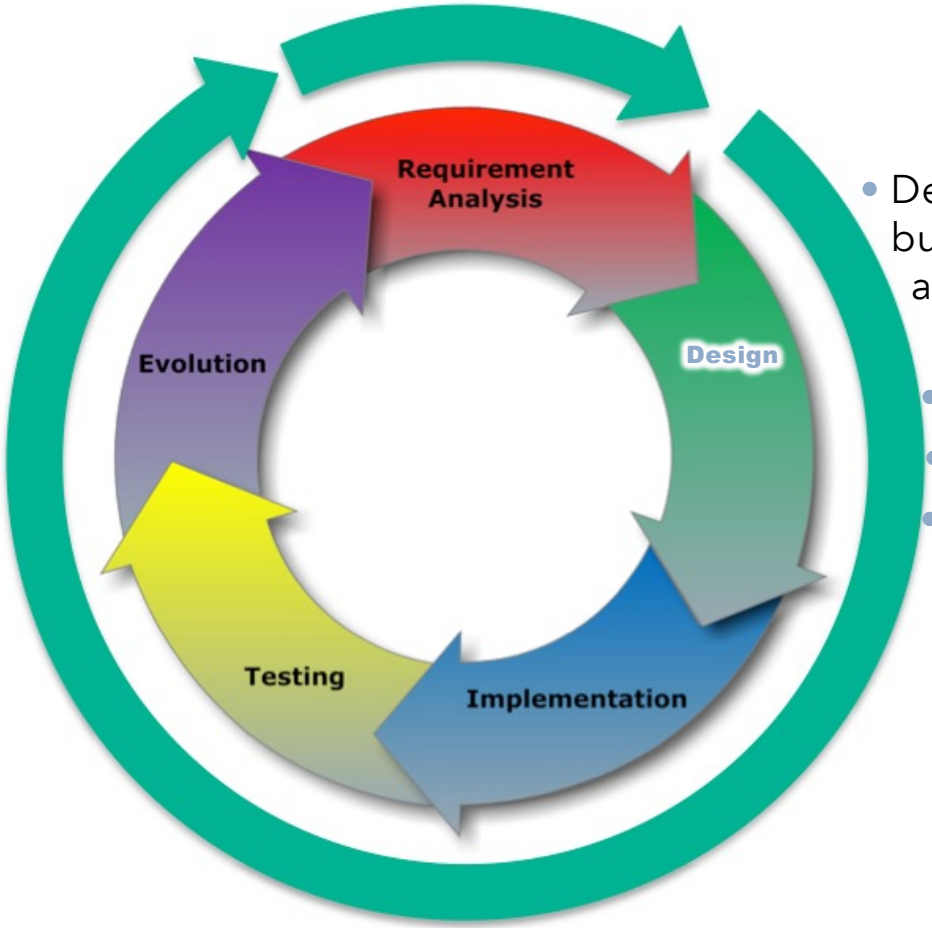


Role of RA in project life-cycle



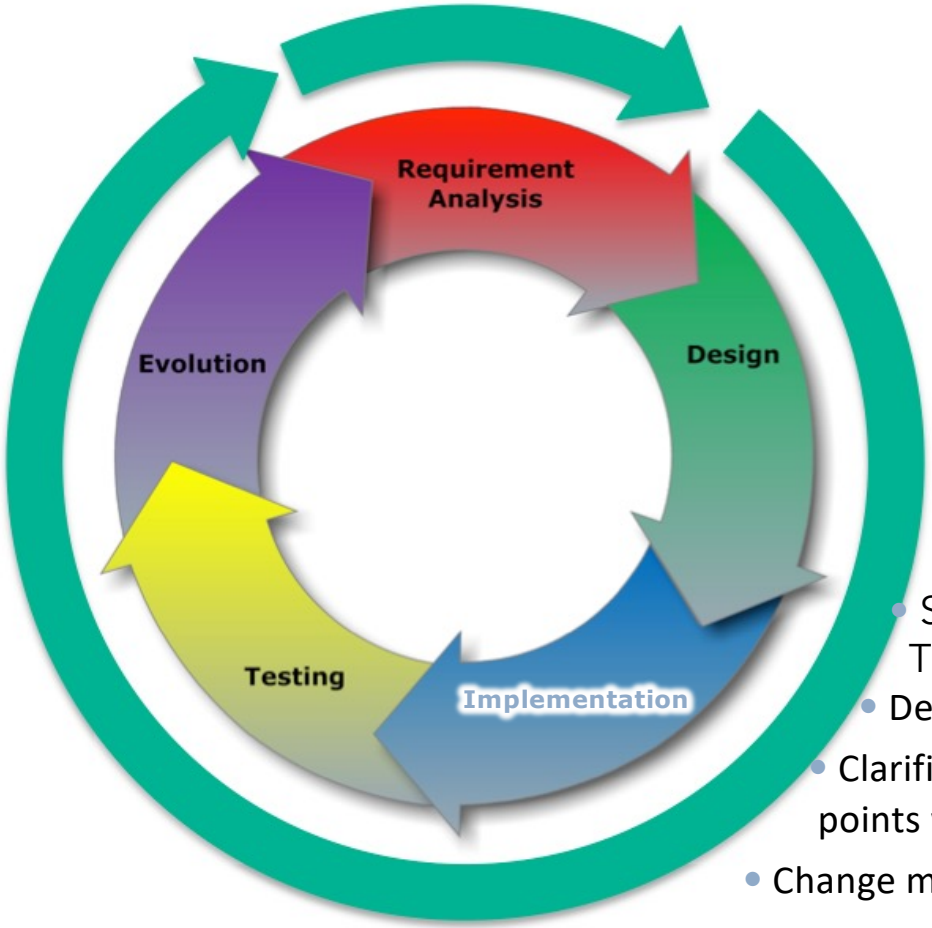
- Analysis of stakeholders
- Analysis of documents
- Elicitation of requirements
- Workshops, interviews
- Analysis of business and user requirements
- Listing of Use Cases

Role of RA in project life-cycle



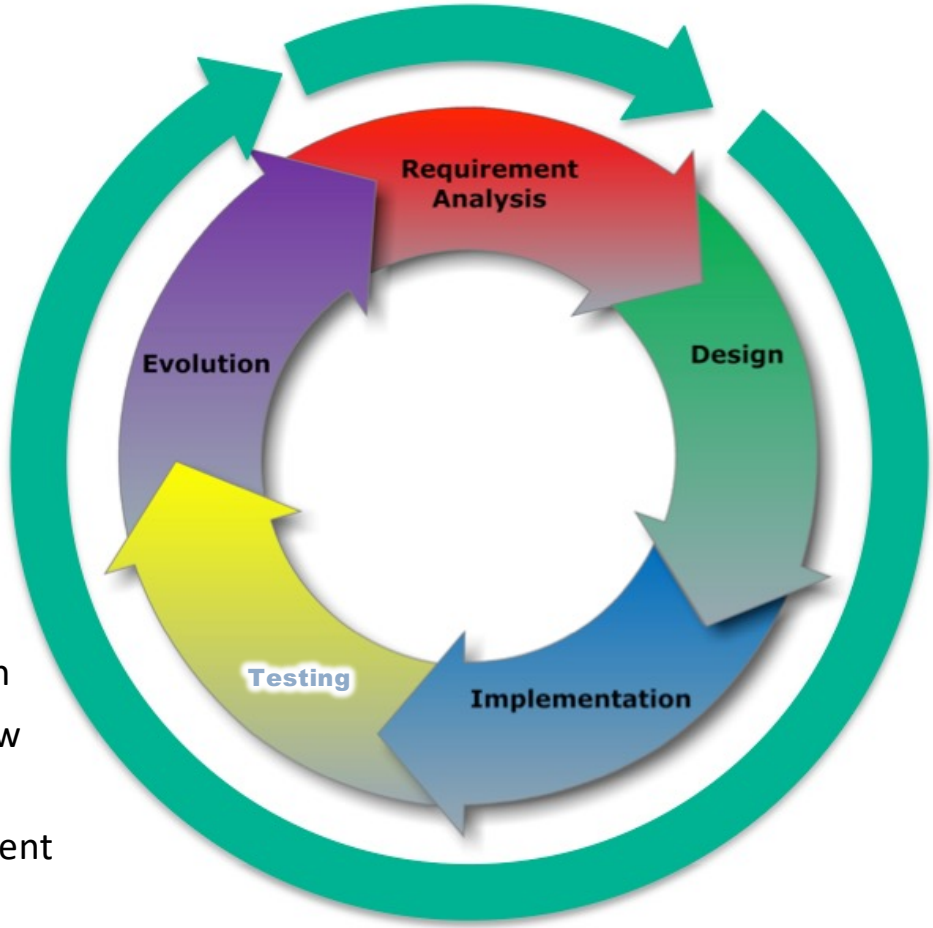
- Detailed specification of: business processes, actors, use cases, interfaces
  - GUI/interaction design
  - Specification reviews
  - Specification approval

Role of RA in project life-cycle



- Spec walkthrough with TPLs, devs
- Developer support
- Clarification of new open points with business
- Change management

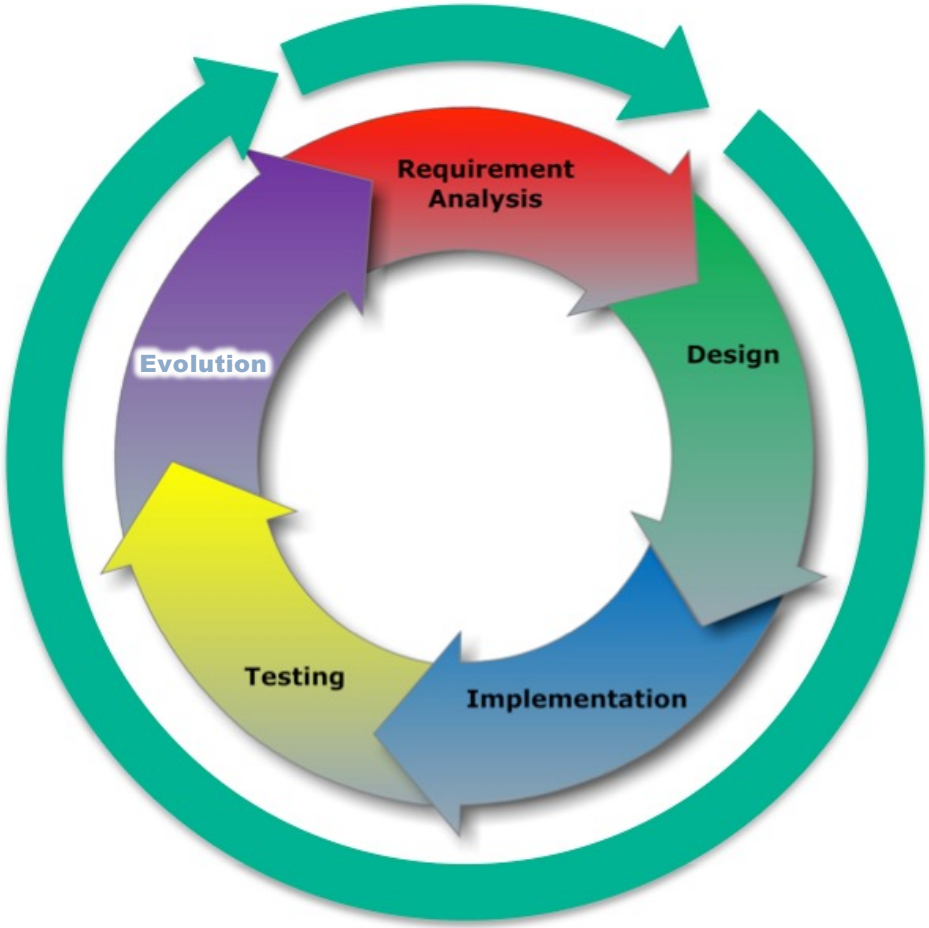
Role of RA in project life-cycle



- Test support
- Defect clarification
- Clarification of new open issues
- Change management

Role of RA in project life-cycle

- Analysis of change requests
- Customer support
- Cleaning up documentation



Different Roles

Be clear…

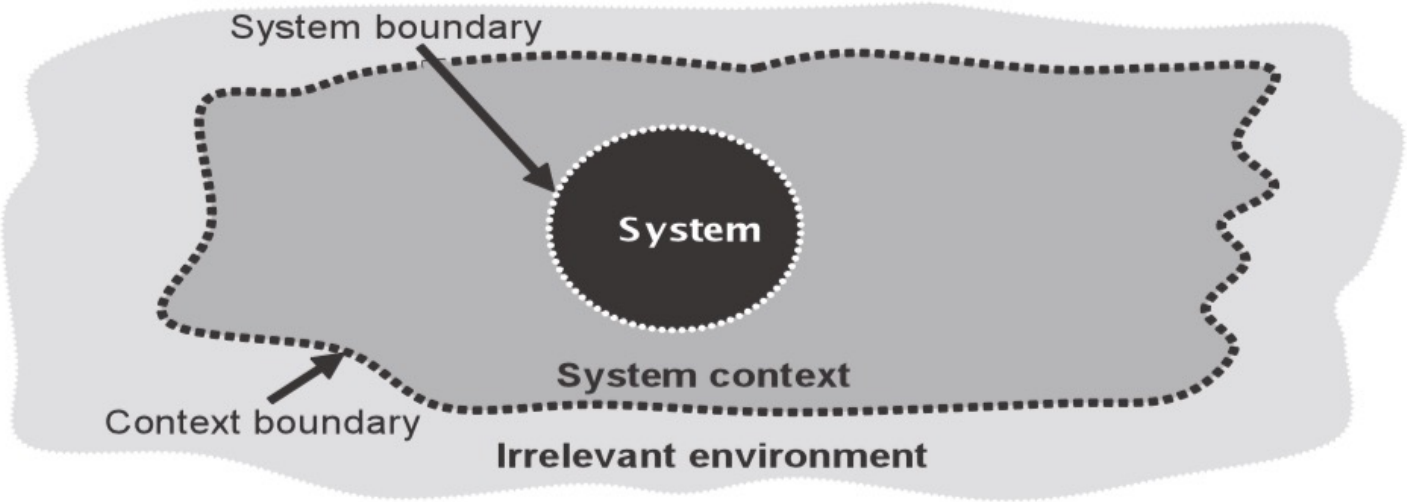
- Requirement **Engineering**:
  - Create and document
- Requirement **Management**:
  - proof, synchronize and manage
- Solution **Design**:
  - Search for solutions and document it



Steps to conduct

Defining System and Context Boundaries

- System- and context boundaries awareness
- Techniques



[Requirements Engineering Fundamentals], p13 ff

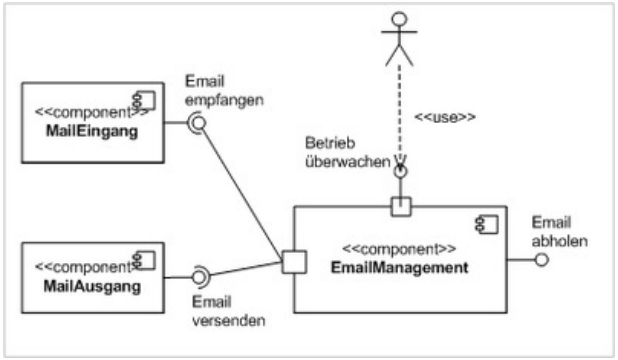
- **FOCUS:** WHAT do we have to create (not HOW)!

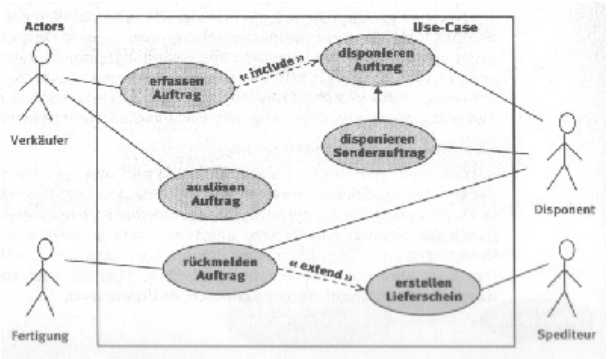
Eliciting Requirements

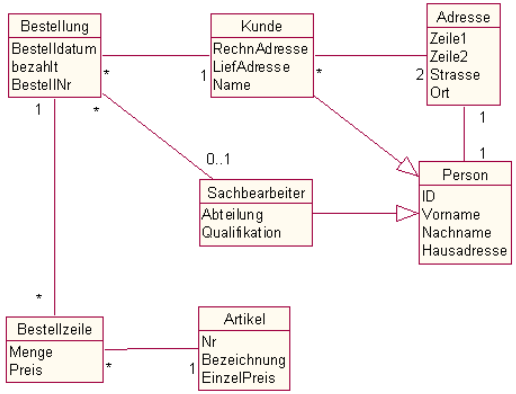
- Stakeholder analyse
  - Get to know all the involved parties
- Requirement sources
  - Stakeholder
  - Documents
  - Systems
- Requirement type
  - Functional
    - → Login
  - Quality / non-functional
    - → Secure storage of log data
  - General regulations or condition
    - System should be live in Summer
    - PCI-DSS compliant

Documentation I

- System component diagram
  - component
  - interface
- Use Case Diagram
  - actor
  - function
- Business Object Model
  - Business object
  - relationships
- Other requirements?
  - List and references

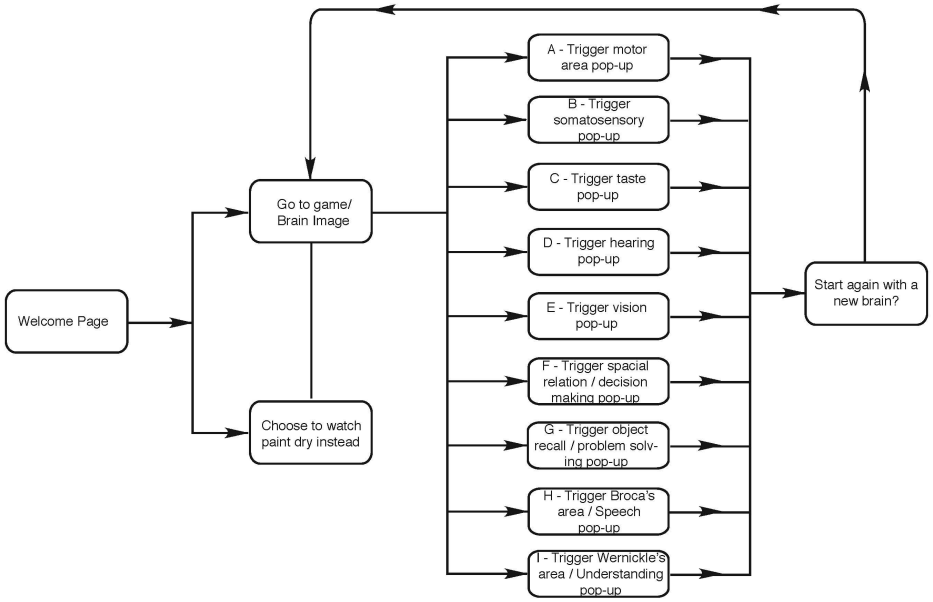






Documentation II

- Screen flows
  - Screens
  - Navigation
- Screens
  - Screen
  - Description of content
- Output / Result
  - Printout, PDF…



- Important: Referencing / clear description!

Requirement Engineering
Requirement Analysis
“Define”

Introduction – What is Requirement Engineering (RE)?

«We don’t have the time for a complete specification»

→ Wrong approach

Correct question: «How much do we have to invest to minimize the risk to a size that we can accept?»

Rule of thumb:

- The effort spent for RE should be inverse to the risk that you’re able to manage»

What's RE in detail ?

Requirements Engineering (Anforderungstechnik) – Understand and describe what the customer wishes and needs. Minimize the risk that the customer gets something he doesn't need or wish for.

- Human centric view
- Target: satisfied customer

Important: Bring your security KNOW-HOW into the GAME! (Customer may not be aware of them)

What is a Requirement: A Definition

1. A condition or capability needed by a user to solve a problem or achieve an objective
2. A condition or capability that must be met or possessed by a system or system component to satisfy a contract, standard, specification, or other formally imposed document
3. A documented representation of a condition or capability as in (1) or (2)

IEEE 610.12-1990

- High-level – Detailed
- Basis for an upcoming contract that you bid for
- Basis of a contract itself

Continuous work…

- During the development process, requirements engineering must **elicit** the stakeholder's requirements, **document** the requirements in a suitable manner, **validate** and **verify** the requirements, and **manage** the requirements over the course of the **entire life cycle** of the system

[Pohl 1996]

What is RE all about?

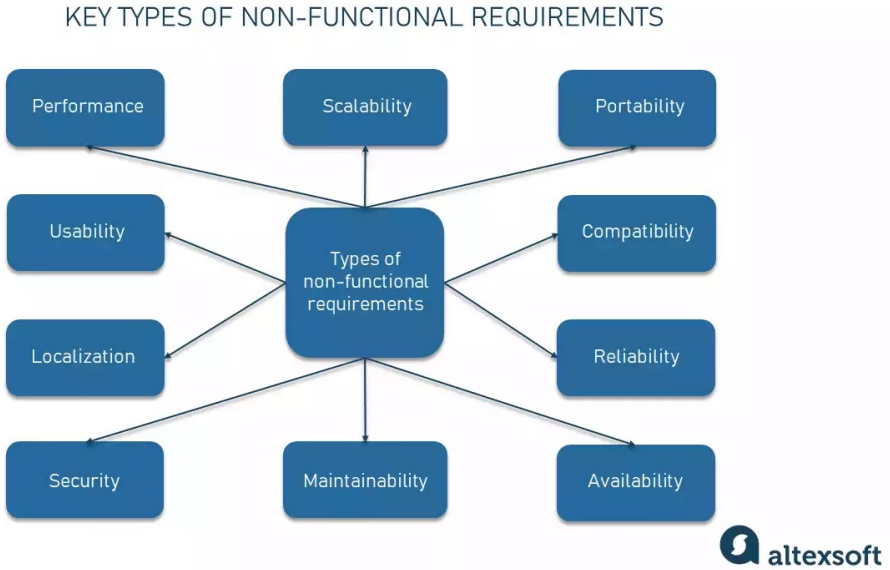
- Requirements engineering is a **systematic** and **disciplined** approach to the specification and management of requirements with the following goals:
  - **Knowing** the **relevant requirements**, achieving a **consensus** among the **stakeholders** about these requirements, **documenting** them according to given standards, and **managing** them systematically
  - Understanding and documenting the stakeholders' desires and needs, then specifying and managing requirements to minimize the risk of delivering a system that does not meet the stakeholders' desires and needs

[Pohl 1996]

Requirement specification

- A systematically represented collection of requirements, typically for a system or component, that satisfies given criteria.
- Different types of groups of requirements
- We focus on non-functional / quality requirements

Additional Info: https://youtu.be/fc-5HJPBZMQ



Requirement Engineering (RE)

- Critical to success for any major development project
- Defects to fix cost more the later you find them
  - Definition asap! → RE Phase
- Reworking / Bug fixing may be up to 50% of your effort on the project

Ex: Coffee vending machine

- Sells coffee
- Accepts Coins
- Accepts cards
- Different flavors/"articles"
- …



4 core activities of RE

1. **Elicitation:** During requirements elicitation, different techniques are used to obtain requirements from stakeholders and other sources and to refine the requirements in greater detail.
2. **Documentation:** During documentation, the elicited requirements are described adequately. Different techniques are used to document the requirements by using natural language or conceptual models.
3. **Validation and negotiation:** In order to guarantee that the predefined quality criteria are met, documented requirements must be validated and negotiated early on.
4. **Management:** Requirements management is orthogonal to all other activities and comprises any measures that are necessary to structure requirements, to prepare them so that they can be used by different roles, to maintain consistency after changes, and to ensure their implementation.

Based on [ISO/IEC/IEEE 29148:2011]

Constraints

- A constraint is a requirement that **limits the solution space** beyond what is necessary for meeting the given functional requirements and quality requirements.
- Different project constraints **influence RE**. For instance, people, domain factors, or organizational constraints (e.g., spatial distribution or temporal availability of project members) have a large impact on the choice of suitable techniques.

Static vs. Agile

- Waterfall model → static
  - All requirements
  - aim at completely eliciting and documenting all requirements in an early project phase before any design or realization decisions are made

- Agile model → „on the move“ → continuous
  - elicit necessary requirements once they are supposed to be implemented as “foretelling” future functionalities is difficult and requirements change over the course of the project

Representation of requirements

Presentation:

- Functionality: Function, data and behaviour
- Attribute: Performance, quality, surrounding conditions

Degree of freedom:

- Choice of the instrument (natural language, structured models, interaction model, formal model)
- Structure
- Precision
- Deepness

Necessary capabilities of a requirements engineer

- Analytic thinking
- Empathy
- Quick thinking
- Communication skills
- Conflict resolution skills
- Moderation skills
- Self-confidence
- Persuasiveness
- Thinking out of the box

Types of requirements

Functional Requirement

- A functional requirement is a requirement concerning a result of behaviour that shall be provided by a function of the system.
- Usually, these requirements are divided into functional requirements, behavioural requirements, and data requirements

Quality Requirement → non functional requirements

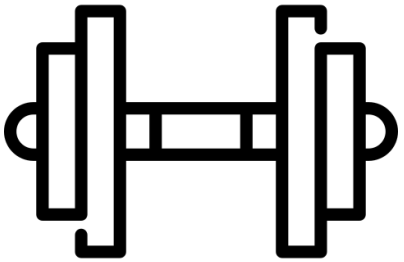
- A quality requirement is a requirement that pertains to a quality concern that is not covered by functional requirements.
- Typically, quality requirements are about the performance, availability, dependability, scalability, or portability of a system. Requirements of this type are frequently classified as non-functional requirements.

Security = non-functional requirements

- Important to collect them
- Discussion with stakeholder
- External or internal policies may exist
- Best-Practice approach



Ex: Write down 20 Requirements of a coffee vending machine, order them in Non-Functional / Functional Requirement



Leftovers / Self Study

- Video Non-Functional Requirements - https://youtu.be/fc-5HJPBZMQ
- Exercises (group or alone)
  - 20 Use cases functional and non-functional of a coffee vending machine
  - 20 non-functional requirements (coffee vending machine or other systems/products)
- Summarize your top 3 take-aways from today

